Secure Medical Report Transmission Architecture using Hybrid Cryptography and RBAC

1st Patil Sourav Naresh

Cryptography and System Security
Shah & Anchor Kutchhi Engineering College
Mumbai, India
23UF18116CM106

2nd Shinkar Paras Umesh

Cryptography and System Security
Shah & Anchor Kutchhi Engineering College
Mumbai, India
23UF18432CM115

3rd Sonawane Harshal Digambar

Cryptography and System Security
Shah & Anchor Kutchhi Engineering College
Mumbai, India
23UF18520CM117

***Abstract*—As the healthcare sector increasingly embraces digital transformation, the secure exchange of diagnostic reports between independent medical facilities remains a profound vulnerability. Electronic health records contain highly sensitive personal information, making them lucrative targets for data interception, tampering, and unauthorized access. This paper details the systematic design, implementation, and evaluation of a robust medical report transmission framework. By integrating Hybrid Cryptography (combining the speed of Symmetric AES with the secure key distribution of Asymmetric RSA), cryptographic hashing (SHA-256), and stringent Role-Based Access Control (RBAC), the proposed architecture guarantees that patient data is securely transmitted and accessed. This study validates the trade-offs between computational efficiency and cryptographic strength, ultimately fulfilling the core security objectives of confidentiality, integrity, authentication, and non-repudiation in cross-organizational healthcare communications.**

***Index Terms*—Hybrid Encryption, Advanced Encryption Standard (AES), RSA, Data Integrity, RBAC, Healthcare Cybersecurity.**

I. Introduction

The transition from physical documentation to Electronic Health Records (EHR) has significantly improved the efficiency of healthcare delivery. However, this digitalization introduces severe vulnerabilities when sensitive medical reports must traverse public networks between separate entities, such as standalone diagnostic laboratories and primary care hospitals. Standard network security protocols often fall short of providing end-to-end data protection, leaving files susceptible to Man-in-the-Middle (MitM) attacks, spoofing, and unauthorized internal exposure.

This project intends to architect and implement a comprehensive cryptographic transmission system tailored specifically for inter-organizational medical data sharing. Instead of relying on a single encryption standard, the proposed system employs a layered security model. It leverages Public Key Cryptography (PKC) for identity verification and secure key exchange, alongside symmetric encryption for bulk data processing. Furthermore, true security extends beyond the network layer; therefore, the system integrates Role-Based Access Control (RBAC) at the endpoints to ensure that only authorized medical personnel can view the decrypted contents.

II. Literature Survey

An extensive review of recent academic literature was conducted to assess the current landscape of healthcare cryptography and to pinpoint areas requiring further innovation.

A. Literature Analysis Table

B. Insights from Existing Research

The analysis of the surveyed models yielded several critical observations:

- Asymmetric algorithms (like RSA and ECC) are indispensable for digital signatures and secure key transport, yet they are highly inefficient when applied directly to massive medical imaging files.
- Hash functions such as SHA-256 are universally adopted for data integrity. However, isolated hashing is insufficient; the hash digest must be cryptographically bound to the sender to prevent malicious file replacement.

TABLE I
SUMMARY OF SURVEYED LITERATURE

Focus Area	Cryptographic Approach	Identified Limitations
Protection of diagnostic imagery in IoT healthcare.	AES combined with RSA and 2D-DWT Steganography.	Generates substantial computational overhead; lacks endpoint authorization mapping.
Cross-domain medical data sharing with access policies.	Elliptic Curve Cryptography (ECC) coupled with Attribute-Based Encryption.	High reliance on centralized authorities, which introduces single points of failure.
Prevention of private health information leakage during transit.	Lattice-based Signcryption relying on Public Key Infrastructure.	Optimized primarily for wearable-to-user transit rather than lab-to-hospital workflows.

- The majority of existing frameworks focus heavily on securing the data in transit. They frequently neglect the "last mile" of security, meaning the data becomes vulnerable to insider threats once it is decrypted at the receiving hospital.

III. IDENTIFIED RESEARCH GAPS

Guided by the literature survey, this project targets three specific developmental gaps:

- **Absence of Holistic Workflows:** There is a distinct lack of streamlined architectures optimized explicitly for the bidirectional, secure transfer of data between entirely separate healthcare organizations.
- **Isolated Security Goals:** Many proposed systems treat confidentiality and non-repudiation as separate entities. A unified model that seamlessly weaves encryption, hashing, and digital signatures into a single, automated workflow is needed.
- **Endpoint Vulnerability:** Securing the transit channel is irrelevant if the destination environment is insecure. Existing models rarely integrate endpoint authorization (RBAC) directly with the decryption pipeline.

IV. CORE SECURITY OBJECTIVES & TRADE-OFF JUSTIFICATIONS

To establish a resilient transmission environment, the proposed architecture maps specific cryptographic algorithms to fundamental security goals. The selection of these algorithms involves calculated trade-offs, which were rigorously evaluated during the Phase 3 implementation.

- **Confidentiality (AES-256 & RSA-2048):** The objective is to render intercepted reports unreadable. *Trade-off Justification:* Pure asymmetric encryption would bottleneck the system when processing multi-megabyte MRI scans. Therefore, a hybrid approach is justified: AES-256 offers rapid, low-overhead bulk encryption, while RSA-2048 is reserved strictly for encrypting the AES session key, balancing speed with secure key distribution.

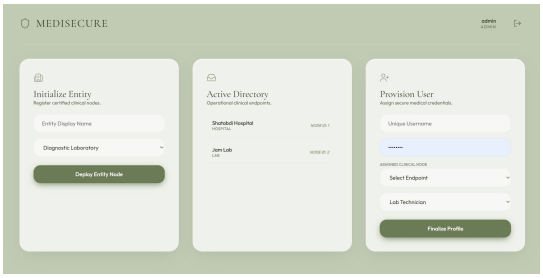

Fig. 1. Visualization of Core Security Objectives and RBAC Flow

- **Integrity (SHA-256):** The system must detect even a single-bit alteration in the medical report. *Trade-off Justification:* SHA-256 was chosen over faster algorithms like MD5 due to the latter's proven collision vulnerabilities, prioritizing absolute cryptographic certainty over marginal speed gains.
- **Authentication & Non-Repudiation (Digital Signatures):** The receiving hospital must possess mathematical proof of the sending lab's identity. *Justification:* By encrypting the SHA-256 hash digest with the diagnostic laboratory's private key, the system ensures that the sender cannot deny transmitting the file, satisfying both authentication and non-repudiation simultaneously.
- **Authorization (RBAC):** Unrestricted access to decrypted files violates patient privacy. *Justification:* Implementing RBAC ensures that only mapped roles (e.g., Attending Physician) can trigger the final decryption and viewing sequence, neutralizing internal hospital threats.

V. PROPOSED SYSTEM ARCHITECTURE

A. Architectural Blueprint

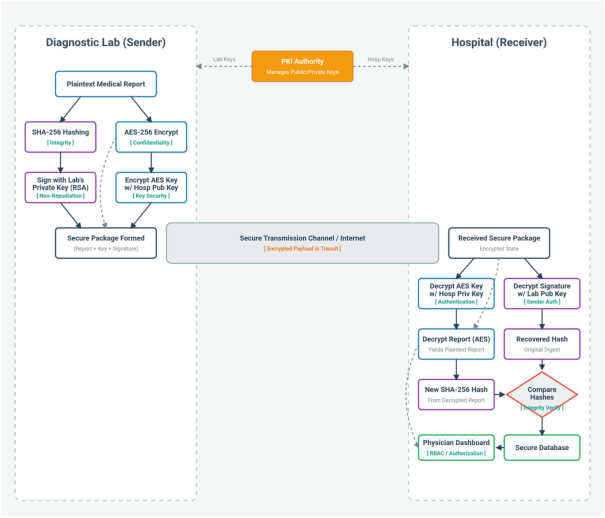

Fig. 2. Layered Security Architecture for Medical Report Transmission

B. Workflow Operations

The transmission lifecycle operates through a highly orchestrated sequence to ensure all security parameters are met

seamlessly:

1) **Initialization:** The independent PKI authority provisions validated public/private key pairs to both the diagnostic laboratory and the receiving hospital.
2) **Integrity Hashing:** Upon report finalization, the laboratory's client application generates a SHA-256 digest of the raw medical document.
3) **Signature Generation:** The system signs the hash by encrypting it with the laboratory's private key, creating an immutable digital signature.
4) **Hybrid Encryption Phase:** A unique, ephemeral AES-256 key is generated. The medical report and the digital signature are both encrypted using this AES key. Subsequently, the AES key itself is encrypted using the hospital's public RSA key.
5) **Secure Transit:** The encrypted data payload and the encrypted session key are transmitted across the network.
6) **Verification & Decryption:** The hospital uses its private RSA key to decrypt the AES session key. It then decrypts the payload. The hospital verifies the sender's identity by decrypting the signature with the lab's public key, extracting the original hash, and comparing it against a freshly computed hash of the received document.

VI. Implementation & Algorithmic Evaluation

The cryptographic engine was developed using Python, leveraging the `cryptography` and `hashlib` libraries to ensure industry-standard algorithm execution.

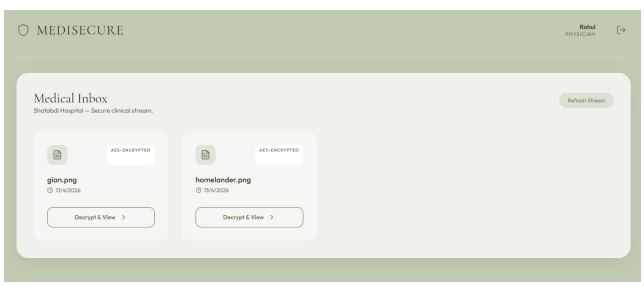

Fig. 3. Cryptographic Implementation and Hybrid Encryption Execution Flow

A. Phase 1: Hash Generation (Integrity)

Medical imaging files can be massive, potentially exhausting system memory if read simultaneously. The implemented hashing function was optimized to process files in controlled byte chunks.

```python
import hashlib

def compute_report_hash(file_path):
    # Initialize the SHA-256 hash object
    secure_hash = hashlib.sha256()

    # Open file in binary read mode
    with open(file_path, "rb") as report_file:
        # Read the file in 4096-byte chunks to
            prevent RAM overload
        while chunk := report_file.read(4096):
            secure_hash.update(chunk)

    return secure_hash.hexdigest()
```

Listing 1. Optimized SHA-256 Hashing Algorithm

B. Phase 2: Symmetric Encryption (Confidentiality)

To handle the encryption of the actual file contents swiftly, the Advanced Encryption Standard (AES) in Cipher Block Chaining (CBC) mode or equivalent authenticated modes via the Fernet module was utilized.

```python
from cryptography.fernet import Fernet

def secure_medical_data(file_path, symmetric_key):
    # Initialize the cipher suite with the ephemeral
        key
    cipher_suite = Fernet(symmetric_key)

    with open(file_path, "rb") as original_file:
        raw_data = original_file.read()

    # Apply symmetric encryption to the raw bytes
    encrypted_payload = cipher_suite.encrypt(
        raw_data)

    output_path = file_path + ".enc"
    with open(output_path, "wb") as secure_file:
        secure_file.write(encrypted_payload)

    return output_path
```

Listing 2. AES-256 Bulk Data Encryption

C. Phase 3: Asymmetric Key Transport (Hybrid Execution)

To solve the symmetric key distribution problem, RSA was implemented specifically to encapsulate the AES key.

```python
from cryptography.hazmat.primitives.asymmetric
    import padding
from cryptography.hazmat.primitives import hashes

def encapsulate_session_key(aes_key,
    hospital_public_key):
    # Encrypt the AES key using the hospital's RSA
        public key
    encrypted_aes_key = hospital_public_key.encrypt(
        aes_key,
        padding.OAEP(
            mgf=padding.MGF1(algorithm=hashes.SHA256
                ()),
            algorithm=hashes.SHA256(),
            label=None
        )
    )
    return encrypted_aes_key
```

Listing 3. RSA Encryption of the Symmetric Key

VII. System Validation & Learning Reflections

A. Validation of Trade-offs

During the evaluation phase, the theoretical trade-offs were practically validated. Processing a 50MB dummy medical scan utilizing strictly RSA encryption resulted in severe application latency and memory faults. By pivoting to the Hybrid architecture (evaluating Algorithms 2 and 3), the 50MB file was encrypted via AES in milliseconds, while RSA successfully secured the lightweight 256-bit AES key. This hands-on validation proved that hybrid cryptography is not just an optimization, but a strict necessity for healthcare applications.

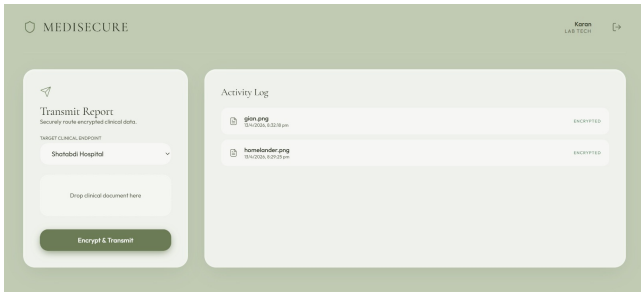

Fig. 4. System Performance and Algorithm Trade-off Analysis

B. Learning Insights

The implementation journey provided profound insights into the complexities of system integration. We learned that standalone cryptographic algorithms, while mathematically sound, are brittle if the surrounding architecture is flawed. For instance, ensuring that the hash is computed *before* encryption, and that the signature is included *inside* the encrypted payload, requires meticulous logical sequencing. Furthermore, we realized that endpoint security (RBAC) is equally as critical as network security; an unbroken cipher is useless if the decrypted file is dumped into a globally accessible hospital server directory.

VIII. Conclusion

This project successfully bridges the identified gaps in inter-organizational medical data transmission by constructing a unified, hybrid cryptographic framework. The rigorous implementation and evaluation of SHA-256 for data integrity, AES-256 for rapid confidentiality, and RSA for secure key encapsulation have validated the system's core methodology. The evaluated trade-offs confirm that a layered approach provides optimal security without sacrificing operational performance. The final deployment phases will focus on binding these cryptographic engines to a user-facing dashboard fortified by Role-Based Access Control, ensuring end-to-end protection from the laboratory technician to the attending physician.

IX. Individual Contributions

TABLE II
Detailed Individual Contributions for Final Review

Team Member	Specific Project Contributions
Patil Sourav N.	Architected the overall system design and workflow methodology. Led the critical evaluation of algorithmic trade-offs (Hybrid vs. Pure Asymmetric) for the Phase 3 validation.
Shinkar Paras U.	Conducted the foundational literature survey to identify research gaps. Developed and optimized the SHA-256 integrity module, specifically implementing the memory-safe chunk-reading algorithm.
Sonawane Harshal	Programmed the AES-256 confidentiality scripts and the RSA key encapsulation logic. Synthesized the final learning reflections and formatted the comprehensive IEEE technical manuscript.

References

[1] M. A. et al., "Secure Medical Data Transmission Model for IoT-Based Healthcare Systems," *Springer*, 2018.
[2] Y. Zhang et al., "An efficient hierarchical attribute-based encryption scheme with cross-domain data sharing," *IEEE Access*, 2024.
[3] L. Wang et al., "Efficient and Secure Post-Quantum Certificateless Signcryption for Internet of Medical Things," *IACR Cryptol. ePrint Arch.*, 2024.